

OPERATION FALSE ASSURANCE

Phase 1 Investigation Report -- Fraudulent Verification and Script Delivery

Team Name	BYEBUST
Phase	Phase 1 -- Fraudulent Verification and Script Delivery
Incident Date (UTC)	2025-10-01
Date Submitted	2026-08-22

Challenge 1 of 10: Affected Workstation and DNS Resolver

Investigation Question: Identify the affected workstation IPv4 address and the DNS resolver it used.

Brief Explanation

One computer on the network got hacked. Its number-name is 160.9.3.101. To visit any website, a computer must first ask a helper computer for directions - this is called a DNS server. This computer's helper was 160.9.3.1.

Technical Method

Query used: `event.dataset:"zeek.dns" AND destination.port:53 | groupby source.ip`

Enumerated all hosts issuing real (unicast, port 53) DNS queries across every imported evidence batch, filtering out LLMNR/NBNS/mDNS broadcast noise (ports 137/5355). This Security Onion instance contains 11 separate import batches; the correct Phase 1 evidence is import batch 495ee14fa7e950512fce637bcc361290, the only one dated 2025-10-01, matching the scenario's stated timeframe. Of the October-2025-dated hosts, 160.9.3.101 has the earliest activity (2025-10-01 09:00:00 UTC), and 51 of its 53 real DNS queries went to resolver 160.9.3.1.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: CuhnDu3ogRkMIJxGHh
- source.ip: 160.9.3.101, source.port: 52322
- destination.ip (resolver): 160.9.3.1, destination.port: 53
- @timestamp: 2025-10-01T09:00:00.000Z

Answer

Workstation: 160.9.3.101 | DNS Resolver: 160.9.3.1

Submitted flag: `CTK{160.9.3.101|160.9.3.1}`

Containment Recommendations

- Isolate workstation 160.9.3.101 from the network pending full forensic review.
- Preserve DNS resolver logs on 160.9.3.1 for correlation with other hosts.

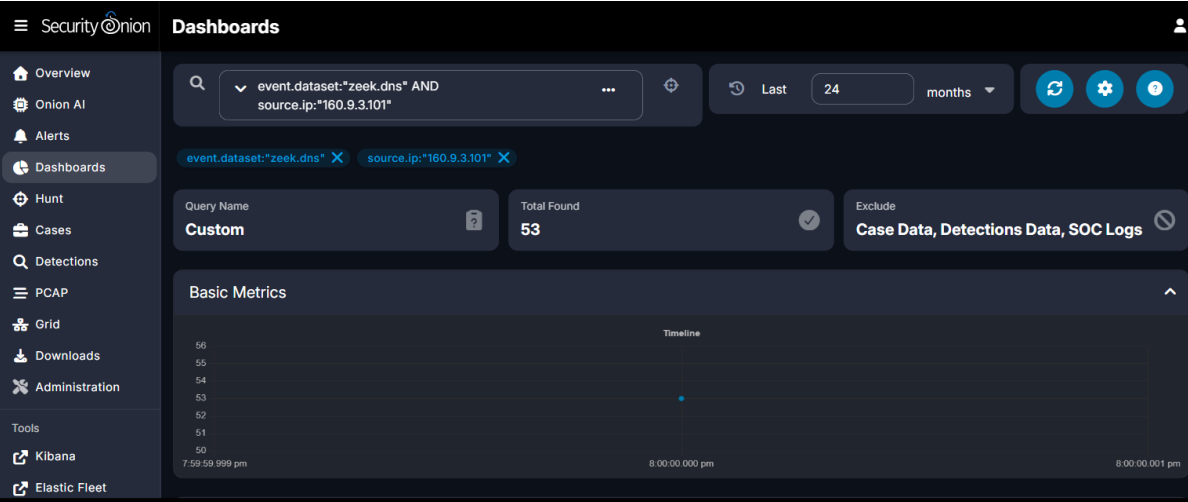
Conclusion

This finding establishes the affected workstation (160.9.3.101) and its DNS resolver (160.9.3.1) as the foundation for the rest of the Phase 1 investigation.

Evidence Screenshots

Figure 1a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	network
>	2025-10-01 05:05:06.420 -04:00	zeek.dns	160.9.3.101	57342	160.9.3.1	53	udp
>	2025-10-01 05:04:55.581 -04:00	zeek.dns	160.9.3.101	62598	160.9.3.1	53	udp
>	2025-10-01 05:04:50.364 -04:00	zeek.dns	160.9.3.101	56317	160.9.3.1	53	udp
>	2025-10-01 05:04:43.576 -04:00	zeek.dns	160.9.3.101	58488	160.9.3.1	53	udp
>	2025-10-01 05:04:41.962 -04:00	zeek.dns	160.9.3.101	5353	224.0.0.251	5353	udp
>	2025-10-01 05:04:40.959 -04:00	zeek.dns	160.9.3.101	5353	224.0.0.251	5353	udp
>	2025-10-01 05:04:40.863 -04:00	zeek.dns	160.9.3.101	56317	160.9.3.1	53	udp
>	2025-10-01 05:04:40.863 -04:00	zeek.dns	160.9.3.101	58488	160.9.3.1	53	udp
>	2025-10-01 05:04:40.812 -04:00	zeek.dns	160.9.3.101	56317	160.9.3.1	53	udp
>	2025-10-01 05:04:39.425 -04:00	zeek.dns	160.9.3.101	58488	160.9.3.1	53	udp

Items per page: 10 1-10 of 53

The backend data fetch took 0.025 seconds. The total round trip took 0.046 seconds.

Figure 1b - Evidence Step
The specific record expanded, showing the timestamp that produced the answer above.

>		2025-10-01 05:00:00.515 -04:00	zeek.dns	160.9.3.101	52322	160.9.3.1	53	udp
>		2025-10-01 05:00:01.227 -04:00	zeek.dns	160.9.3.101	52322	160.9.3.1	53	udp
>		2025-10-01 05:00:01.236 -04:00	zeek.dns	160.9.3.101	55036	160.9.3.1	53	udp
>		2025-10-01 05:00:02.031 -04:00	zeek.dns	160.9.3.101	52322	160.9.3.1	53	udp
>		2025-10-01 05:00:02.262 -04:00	zeek.dns	160.9.3.101	55036	160.9.3.1	53	udp
>		2025-10-01 05:00:02.262 -04:00	zeek.dns	160.9.3.101	59603	160.9.3.1	53	udp
>		2025-10-01 05:00:02.263 -04:00	zeek.dns	160.9.3.101	53171	160.9.3.1	53	udp
>		2025-10-01 05:00:02.312 -04:00	zeek.dns	160.9.3.101	59603	160.9.3.1	53	udp
>		2025-10-01 05:00:02.990 -04:00	zeek.dns	160.9.3.101	59603	160.9.3.1	53	udp

Items per page: 10

1-10 of 53



The backend data fetch took 0.025 seconds. The total round trip took 0.041 seconds.

Challenge 2 of 10: First Web Domain

Investigation Question: What was the first web domain queried by the workstation, and what IPv4 address was returned?

Brief Explanation

The very first thing the computer did was visit a website called `www.sepco.com`. That website looked real but was actually a trick, made to look like a 'verification' page. The trick website's address was `148.72.11.102`.

Technical Method

Query used: `source.ip:"160.9.3.101"` sorted ascending by Timestamp

Sorted all events for `160.9.3.101` (all datasets) ascending by timestamp. The very first record for this host is a `zeek.dns` query at exactly `2025-10-01 09:00:00.000 UTC` - the deliberate start-of-capture marker - resolving `www.sepco.com` to a single, unambiguous IPv4.

Relevant Infrastructure

Type	Domain / IP	Port	Purpose / Observation
Fraudulent Verification Page	<code>www.sepco.com</code> (<code>148.72.11.102</code>)	443	First site visited; the fake verification lure

Supporting Evidence (Security Onion / Zeek)

- `log.id.uid:` `CuhnDu3ogRkMIJxGHh`
- `dns.query.name:` `www.sepco.com`
- `dns.resolved_ip:` [`148.72.11.102`] (single answer, no ambiguity)
- `@timestamp:` `2025-10-01T09:00:00.000Z`

Answer

Domain: `www.sepco.com` | **IP Address:** `148.72.11.102`

Submitted flag: `CTK{www.sepco.com|148.72.11.102}`

Containment Recommendations

- Block `www.sepco.com` and `148.72.11.102` at DNS/web proxy and perimeter firewall.
- Search enterprise DNS logs for other hosts resolving `www.sepco.com`.

Conclusion

The workstation's initial compromise began with the fraudulent verification page `www.sepco.com` (`148.72.11.102`), matching the scenario's described lure.

Evidence Screenshots

Figure 2a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.

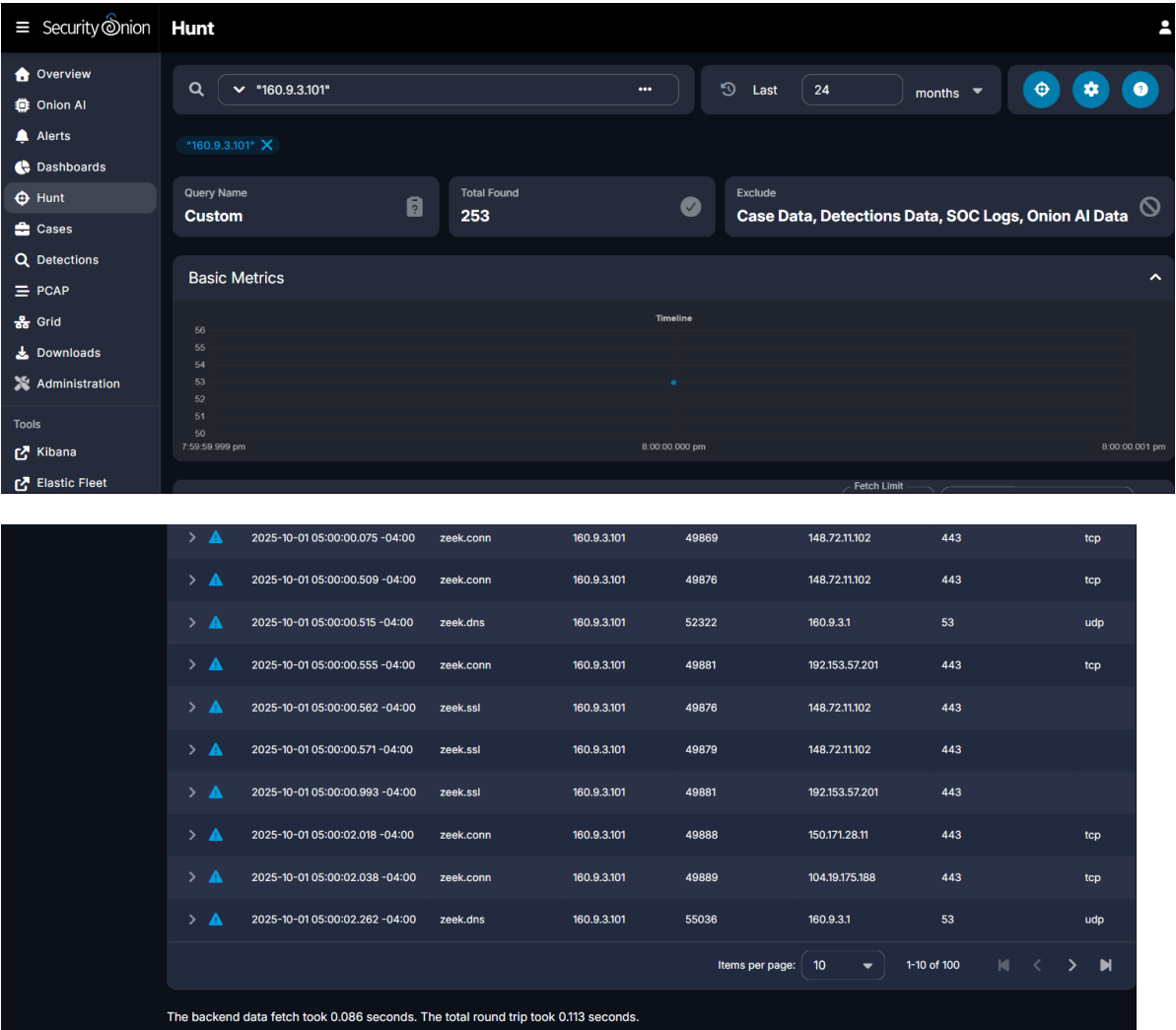


Figure 2b - Evidence Step

The specific record expanded, showing the details that produced the answer above.

Challenge 3 of 10: Next TLS Server Name

Investigation Question: Which TLS server name appeared immediately after the first website, and what IPv4 address did it use?

Brief Explanation

Right after the trick website, the computer was sent to a second, different website - without anyone clicking anything. That second website was called loughlas.com, at address 192.153.57.201.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.ssl"

Pulled all zeek.ssl events for the affected workstation, ascending by timestamp. After six parallel TLS sessions to www.sepco.com (148.72.11.102), the next distinct TLS server_name is loughlas.com at 192.153.57.201, seen at 2025-10-01 09:00:00.993 UTC.

Relevant Infrastructure

Type	Domain / IP	Port	Purpose / Observation
Redirect / Second-stage Site	loughlas.com (192.153.57.201)	443	Site contacted immediately after the verification page

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: CPyXoy4rWDbQ1I1fY4
- ssl.server_name: loughlas.com, ssl.version: TLSv1.2
- destination.ip: 192.153.57.201, destination.port: 443
- @timestamp: 2025-10-01T09:00:00.993Z

Answer

Domain: loughlas.com | **IP Address:** 192.153.57.201

Submitted flag: CTK{loughlas.com|192.153.57.201}

Containment Recommendations

- Block loughlas.com and 192.153.57.201 at DNS/web proxy and perimeter firewall.
- Review TLS SNI logs enterprise-wide for other hosts contacting loughlas.com.

Conclusion

loughlas.com represents the transition point from the fraudulent verification page to the attacker's script-delivery infrastructure.

Evidence Screenshots

Figure 3a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.

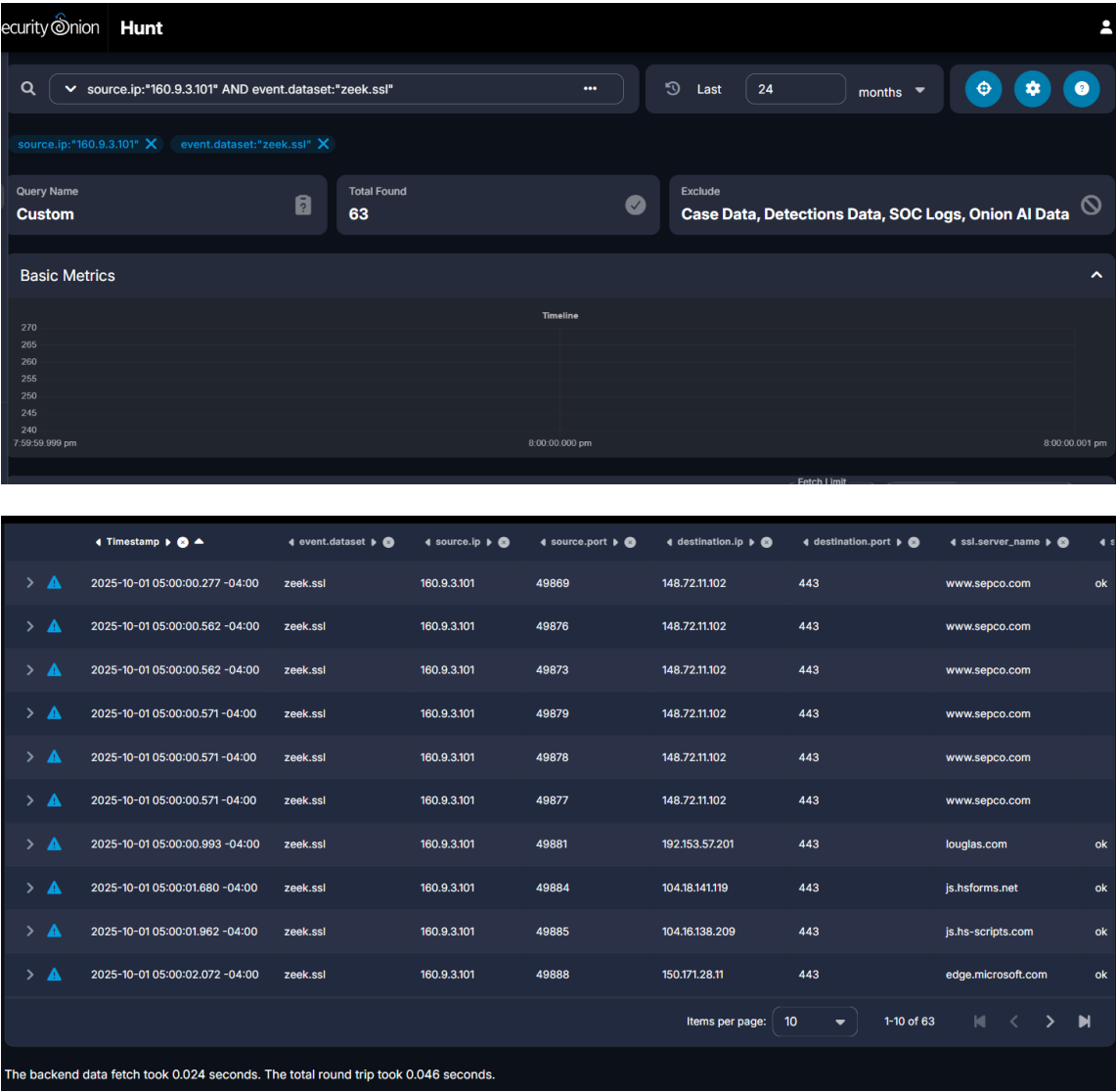


Figure 3b - Evidence Step

The specific record expanded, showing the details that produced the answer above.

  data_stream.namespace	so
  data_stream.type	logs
  destination.as.ip	192.153.57.201
  destination.as.network	192.153.57.0/24
  destination.as.number	399629

Challenge 4 of 10: PowerShell Delivery Server

Investigation Question: Identify the IPv4 address and TCP port of the server that delivered the PowerShell-related files.

Brief Explanation

A bad computer far away sent two harmful files to the victim's computer. That bad computer's address was 85.209.129.105. It used a special 'door' (called a port) numbered 2020 to send the files - not the normal doors websites use.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.file"

Pulled all zeek.file records for the affected workstation. scriptv2.ps1 and test.ps1 (PowerShell scripts) and a ~26 MB test.zip payload were all delivered from 85.209.129.105 over TCP port 2020 (non-standard HTTP port).

Relevant Infrastructure

Type	Domain / IP	Port	Purpose / Observation
Script & Payload Delivery Server	85.209.129.105	2020	Served both PowerShell scripts and the 26 MB archive; hosted in Finland

Malware / Tool Identification

PowerShell script delivery (scriptv2.ps1, test.ps1) via HTTP on non-standard port 2020, consistent with a lightweight HTTP file server used as attacker staging infrastructure.

Supporting Evidence (Security Onion / Zeek)

- destination.ip: 85.209.129.105, destination.port: 2020
- file.name: scriptv2.ps1, test.ps1
- file.mime_type: text/plain
- @timestamp: 2025-10-01T09:00:47.505Z (scriptv2.ps1)

Answer

Server: 85.209.129.105 | **Port:** 2020

Submitted flag: CTK{85.209.129.105|2020}

Containment Recommendations

- Block 85.209.129.105 (all ports, especially TCP/2020) at the perimeter firewall.
- Hunt enterprise-wide for any other host contacting 85.209.129.105.

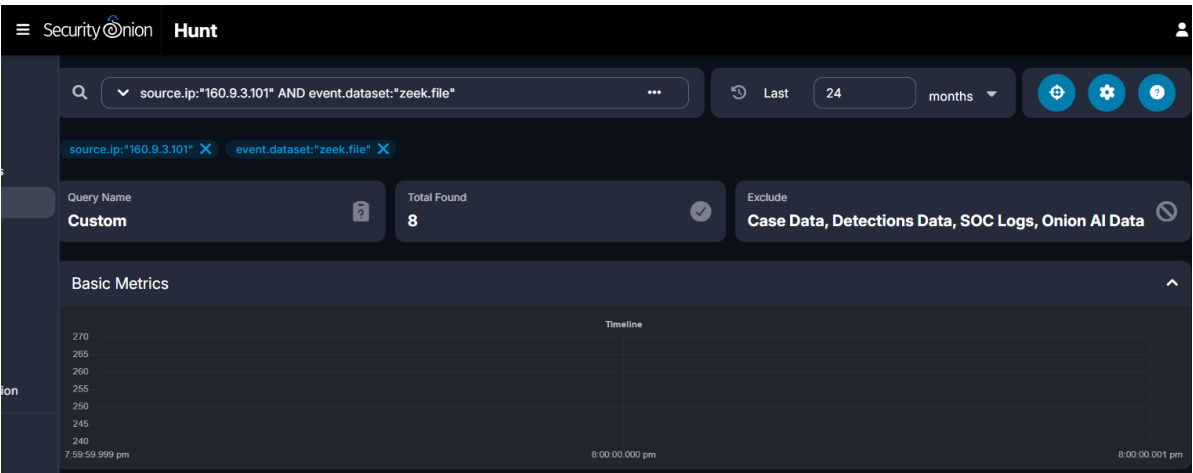
Conclusion

85.209.129.105:2020 functioned as the central staging/delivery server for both PowerShell scripts and the large archive payload in this intrusion.

Evidence Screenshots

Figure 4a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



	Timestamp	event.dataset	source.ip	destination.ip	file.name	file.mime_type	file.source	file.bytes
>	2025-10-01 05:00:47.505 -04:00	zeek.file	160.9.3.101	85.209.129.105	scriptv2.ps1	text/plain	HTTP	16255
>	2025-10-01 05:00:53.871 -04:00	zeek.file	160.9.3.101	85.209.129.105	test.ps1	text/plain	HTTP	30691
>	2025-10-01 05:00:57.970 -04:00	zeek.file	160.9.3.101	85.209.129.105		text/plain	HTTP	14
>	2025-10-01 05:00:58.749 -04:00	zeek.file	160.9.3.101	85.209.129.105			HTTP	4
>	2025-10-01 05:01:10.525 -04:00	zeek.file	160.9.3.101	64.95.13.172	f.txt	text/plain	HTTP	7054
>	2025-10-01 05:01:15.089 -04:00	zeek.file	160.9.3.101	104.16.231.132		text/plain	HTTP	2788
>	2025-10-01 05:01:19.215 -04:00	zeek.file	160.9.3.101	85.209.129.105	test.zip	application/zip	HTTP	26922546
>	2025-10-01 05:04:38.021 -04:00	zeek.file	160.9.3.101	142.250.114.102	json.txt	text/plain	HTTP	

Items per page: 10 1-8 of 8

The backend data fetch took 0.02 seconds. The total round trip took 0.024 seconds.

Figure 4b - Evidence Step

The specific record expanded, showing the details that produced the answer above.

 	observer.name	cyberseco
 	server.ip	85.209.129.105
 	server.port	2020
 	source.as.ip	160.9.3.101
 	source.as.network	160.9.0.0/16

 	destination.geo.country_iso_code	FI
 	destination.geo.country_name	Finland
 	destination.geo.ip	85.209.129.105
 	destination.geo.location.lat	60.1719
 	destination.geo.location.lon	24.9347

Challenge 5 of 10: First Script Delivery

Investigation Question: What URI delivered the first script, and what filename was recorded for the response?

Brief Explanation

The first harmful file was named scriptv2.ps1. It is a small program written for Windows PowerShell (a tool built into Windows for running commands). It was fetched from a specific spot on the bad computer called /19.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.http"

Listed all zeek.http events for the affected workstation, ascending by timestamp. The first HTTP request to the delivery server (05:00:47.201 -04:00) was GET /19 (curl/8.14.1 user-agent), 200 OK, returning file scriptv2.ps1 (16,255 bytes).

Malware / Tool Identification

First-stage script scriptv2.ps1 retrieved via curl (not yet PowerShell), suggesting an initial loader/dropper stage distinct from the workstation's own PowerShell process.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: CqGE2b39Yb7ePbbQ25
- http.method: GET, http.uri: /19
- http.useragent: curl/8.14.1
- file.resp_filenames: scriptv2.ps1
- @timestamp: 2025-10-01T09:00:47.201Z

Answer

URI: /19 | **Filename:** scriptv2.ps1

Submitted flag: CTK{/19|scriptv2.ps1}

Containment Recommendations

- Add URI pattern /19 on 85.209.129.105:2020 to IDS/WAF detection rules.
- Search endpoint/EDR telemetry for scriptv2.ps1 execution on other hosts.

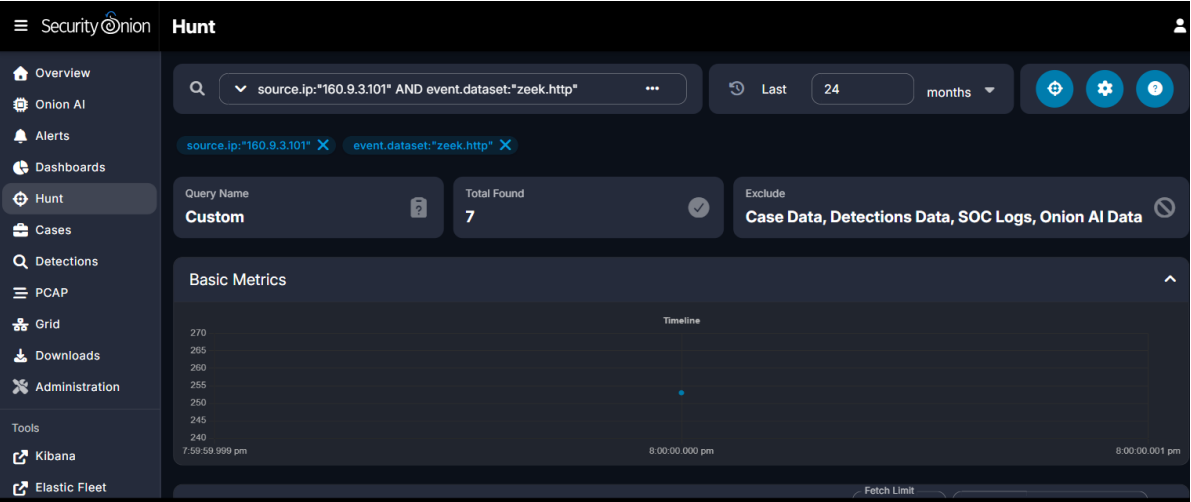
Conclusion

URI /19 on the delivery server marks the first script-delivery event in the intrusion chain, recorded under the filename scriptv2.ps1.

Evidence Screenshots

Figure 5a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	http.me
> ▲	2025-10-01 05:00:47.201 -04:00	zeek.http	160.9.3.101	63641	85.209.129.105	2020	GET
> ▲	2025-10-01 05:00:53.575 -04:00	zeek.http	160.9.3.101	63645	85.209.129.105	2020	GET
> ▲	2025-10-01 05:00:57.970 -04:00	zeek.http	160.9.3.101	63649	85.209.129.105	2020	POST
> ▲	2025-10-01 05:00:59.526 -04:00	zeek.http	160.9.3.101	63651	64.95.13.172	80	GET
> ▲	2025-10-01 05:01:15.089 -04:00	zeek.http	160.9.3.101	63654	104.16.231.132	80	POST
> ▲	2025-10-01 05:01:18.920 -04:00	zeek.http	160.9.3.101	63656	85.209.129.105	2020	GET
> ▲	2025-10-01 05:04:37.969 -04:00	zeek.http	160.9.3.101	64928	142.250.114.102	80	GET

Items per page: 10 1-7 of 7

The backend data fetch took 0.02 seconds. The total round trip took 0.025 seconds.

Figure 5b - Evidence Step
The specific record expanded, showing the details that produced the answer above.

  file.resp_filenames	["scriptv2.ps1"]
  file.resp_mime_types	["text/plain"]
  hash.ja4h	ge11nn030000_fe444ad14866_000000000000_000000000000
  http.method	GET
  http.request.body.length	0
  http.response.body.length	16255
  http.status_code	200
  http.status_message	OK
  http.trans_depth	1
  http.uri	/19

Challenge 6 of 10: Second Script Delivery

Investigation Question: What URI delivered the second script, and what filename was recorded for the response?

Brief Explanation

A second harmful file came next. It was named test.ps1, and it came from a spot called /test112. This time, it was Windows PowerShell itself - not a person or a simple tool - that grabbed the file.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.http"

The second HTTP request to the delivery server (05:00:53.575 -04:00) was GET /test112, this time using a genuine WindowsPowerShell/5.1.26100.4768 user-agent, returning file test.ps1 (30,691 bytes) - indicating the first script had already executed.

Malware / Tool Identification

Second-stage script test.ps1 retrieved by a genuine PowerShell process, indicating scriptv2.ps1 executed and initiated this follow-on download.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: Cktd803yzkrrCkYDyc
- http.method: GET, http.uri: /test112
- http.useragent: WindowsPowerShell/5.1.26100.4768
- file.resp_filenames: test.ps1
- @timestamp: 2025-10-01T09:00:53.575Z

Answer

URI: /test112 | **Filename:** test.ps1

Submitted flag: CTK{/test112|test.ps1}

Containment Recommendations

- Add URI pattern /test112 on 85.209.129.105:2020 to IDS/WAF detection rules.
- Enable PowerShell script block logging on 160.9.3.101 and similar hosts.

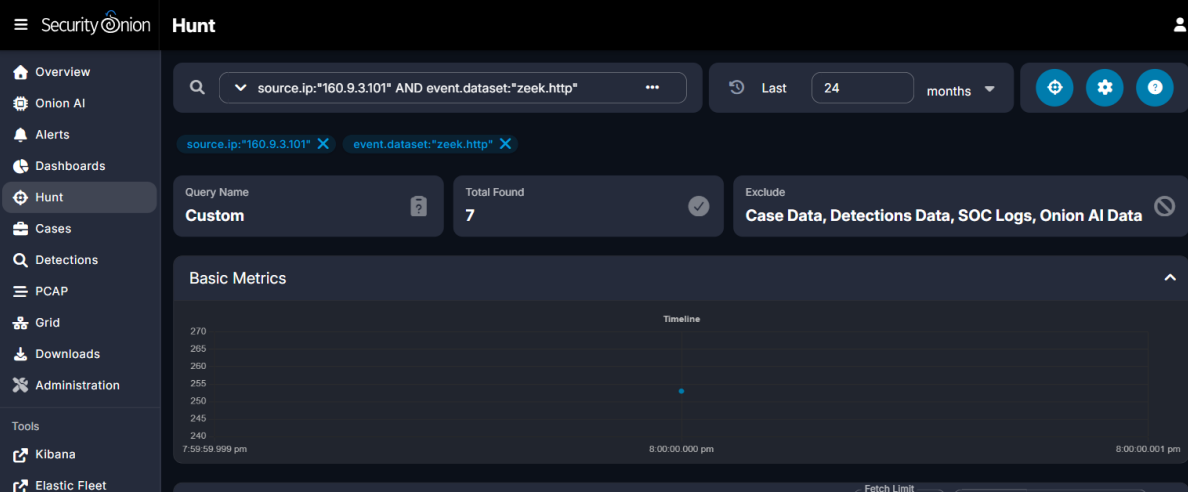
Conclusion

The change in user-agent between the first (curl) and second (genuine PowerShell) requests is a key indicator that scriptv2.ps1 executed and autonomously fetched test.ps1.

Evidence Screenshots

Figure 6a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	http.method
> ▲	2025-10-01 05:00:47.201 -04:00	zeek.http	160.9.3.101	63641	85.209.129.105	2020	GET
> ▲	2025-10-01 05:00:53.575 -04:00	zeek.http	160.9.3.101	63645	85.209.129.105	2020	GET
> ▲	2025-10-01 05:00:57.970 -04:00	zeek.http	160.9.3.101	63649	85.209.129.105	2020	POST
> ▲	2025-10-01 05:00:59.526 -04:00	zeek.http	160.9.3.101	63651	64.95.13.172	80	GET
> ▲	2025-10-01 05:01:15.089 -04:00	zeek.http	160.9.3.101	63654	104.16.231.132	80	POST
> ▲	2025-10-01 05:01:18.920 -04:00	zeek.http	160.9.3.101	63656	85.209.129.105	2020	GET
> ▲	2025-10-01 05:04:37.969 -04:00	zeek.http	160.9.3.101	64928	142.250.114.102	80	GET

Items per page: 10 1-7 of 7

The backend data fetch took 0.02 seconds. The total round trip took 0.025 seconds.

Figure 6b - Evidence Step

The specific record expanded, showing the details that produced the answer above.

  file.resp_filenames	["test.ps1"]
  file.resp_mime_types	["text/plain"]
  hash.sha4h	ge11nn030000_b0d6a43aa599_000000000000_000000000000
  http.method	GET
  http.request.body.length	0
  http.response.body.length	30691
  http.status_code	200
  http.status_message	OK
  http.trans_depth	1
  http.uri	/test112

Challenge 7 of 10: Notification Request

Investigation Question: Which HTTP method and URI were used for the notification request, and what response status was returned?

Brief Explanation

After the files ran, the victim's computer sent a tiny message back to the bad computer, almost like saying 'it worked!' The message went to a spot called /notify, and the bad computer answered back 'OK'.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.http"

POST /notify to 85.209.129.105:2020 at 2025-10-01 09:00:57.970 UTC; 14-byte request, 4-byte response, status 200 OK - a beacon/check-in confirming script execution.

Command-and-Control Assessment

POST /notify (14-byte request, 4-byte response) is assessed as a lightweight C2 check-in/beacon confirming successful execution of the delivered PowerShell scripts.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: C8kmUG21ryBXI6qCA8
- http.method: POST, http.uri: /notify
- http.status_code: 200
- @timestamp: 2025-10-01T09:00:57.970Z

Answer

Method: POST | URI: /notify | Response Status: 200

Submitted flag: CTK{POST|/notify|200}

Containment Recommendations

- Add URI pattern /notify on 85.209.129.105:2020 to IDS/WAF detection rules as a beacon indicator.

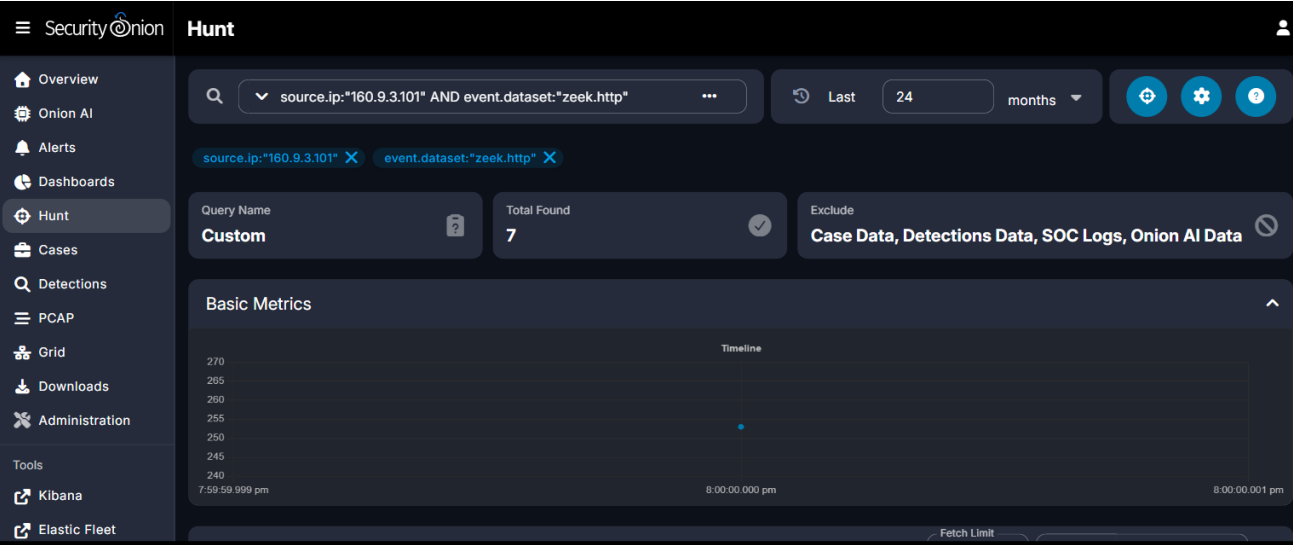
Conclusion

The /notify POST request functions as a check-in beacon, marking the point at which the attacker's infrastructure was informed that script execution succeeded on the victim host.

Evidence Screenshots

Figure 7a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	http.me
>	2025-10-01 05:00:47.201 -04:00	zeek.http	160.9.3.101	63641	85.209.129.105	2020	GET
>	2025-10-01 05:00:53.575 -04:00	zeek.http	160.9.3.101	63645	85.209.129.105	2020	GET
>	2025-10-01 05:00:57.970 -04:00	zeek.http	160.9.3.101	63649	85.209.129.105	2020	POST
>	2025-10-01 05:00:59.526 -04:00	zeek.http	160.9.3.101	63651	64.95.13.172	80	GET
>	2025-10-01 05:01:15.089 -04:00	zeek.http	160.9.3.101	63654	104.16.231.132	80	POST
>	2025-10-01 05:01:18.920 -04:00	zeek.http	160.9.3.101	63656	85.209.129.105	2020	GET
>	2025-10-01 05:04:37.969 -04:00	zeek.http	160.9.3.101	64928	142.250.114.102	80	GET

Items per page: 10 1-7 of 7

The backend data fetch took 0.02 seconds. The total round trip took 0.025 seconds.

Figure 7b - Evidence Step
The specific record expanded, showing the details that produced the answer above.

  http.method	POST
  http.request.body.length	14
  http.response.body.length	4
  http.status_code	200
  http.status_message	OK
  http.trans_depth	1
  http.uri	/notify

Challenge 8 of 10: Cloudflare Tunnel Transaction

Investigation Question: Identify the Cloudflare Tunnel hostname, POST URI, and response status code.

Brief Explanation

The attacker also used a free, temporary 'tunnel' from Cloudflare (a real, trusted company) to hide where they truly were. It was used only once, and the far end said 'not found'.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.http"

POST /BSVjy5VpVrg0 to maintaining-shelter-bailey-ordinance.trycloudflare.com at 2025-10-01 09:01:15.089 UTC; 2,788-byte request, 404 Not Found response.

Relevant Infrastructure

Type	Domain / IP	Port	Purpose / Observation
Disposable Relay	maintaining-shelter-bailey-ordinance.trycloudflare.com	80	Temporary Cloudflare Tunnel used to relay a POST request; hides the true backend

Command-and-Control Assessment

Use of a trycloudflare.com quick-tunnel (auto-generated random subdomain) to relay a POST request is a known technique for hiding the true backend C2 server behind Cloudflare's legitimate infrastructure.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: Cp61j16BYOZNBVlca
- http.method: POST, http.uri: /BSVjy5VpVrg0
- http.virtual_host: maintaining-shelter-bailey-ordinance.trycloudflare.com
- http.status_code: 404
- @timestamp: 2025-10-01T09:01:15.089Z

Answer

Hostname: maintaining-shelter-bailey-ordinance.trycloudflare.com | **URI:** /BSVjy5VpVrg0 | **Status:** 404

Submitted flag: CTK{maintaining-shelter-bailey-ordinance.trycloudflare.com|/BSVjy5VpVrg0|404}

Containment Recommendations

- Block the specific trycloudflare.com hostname at DNS/web proxy.

- Alert on any *.trycloudflare.com traffic enterprise-wide as a detection rule.

Conclusion

The Cloudflare Tunnel transaction demonstrates the attacker's use of disposable, legitimate-looking infrastructure to relay traffic, complicating IP-based blocking.

Evidence Screenshots

Figure 8a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.

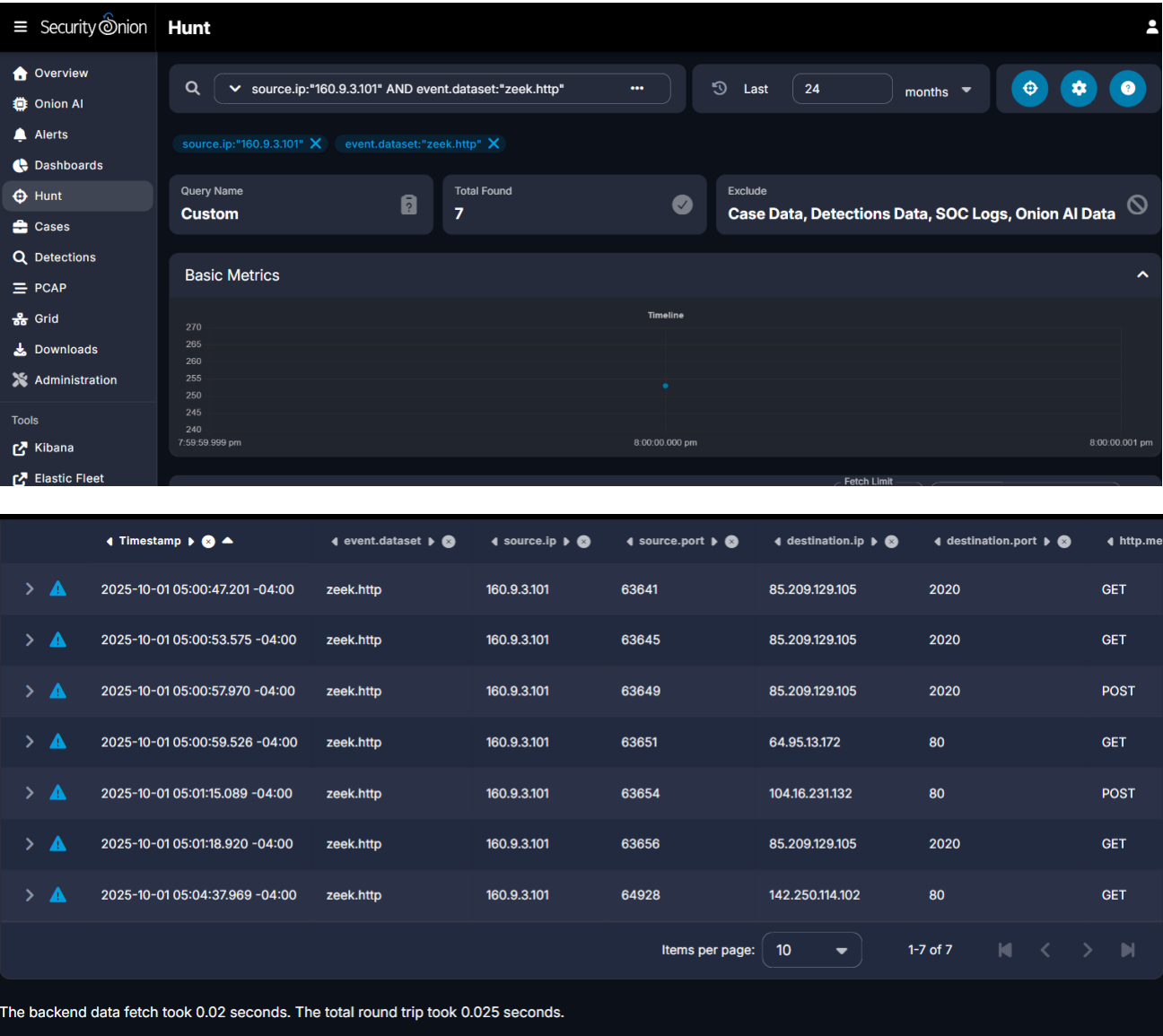


Figure 8b - Evidence Step

The specific record expanded, showing the details that produced the answer above.

  http.status_code	404
  http.status_message	Not Found
  http.trans_depth	1
  http.uri	/BSVjy5VpVrgO
  http.useragent	Mozilla/5.0 (Windows NT; Windows NT 10.0; en-US) WindowsPowerShell/5.1.26100.4768
  http.version	1.1
  http.virtual_host	maintaining-shelter-bailey-ordinance.trycloudflare.com

Challenge 9 of 10: Large Archive Transfer

Investigation Question: What URI delivered the large archive? Provide the recorded filename and response body size.

In Plain Words

The biggest file sent was a large zipped folder - about 26 megabytes, roughly the size of a few hundred photos - named test.zip. It came from a spot called /testl11.

Technical Method

Query used: source.ip:"160.9.3.101" AND event.dataset:"zeek.http"

GET /testl11 to 85.209.129.105:2020 at 2025-10-01 09:01:18.920 UTC; 200 OK, response body 26,922,546 bytes, recorded filename test.zip (application/zip), matching the zeek.file record exactly.

Malware / Tool Identification

A large (~26 MB) archive, test.zip, delivered as the final payload - likely containing a secondary implant or tooling given its size relative to the earlier plaintext scripts.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: C2qZ713cWuXatbYjDb
- http.method: GET, http.uri: /testl11
- http.response.body.length: 26922546
- file.name: test.zip, file.mime_type: application/zip
- @timestamp: 2025-10-01T09:01:18.920Z

Answer

URI: /testl11 | **Filename:** test.zip | **Size:** 26,922,546 bytes

Submitted flag: CTK{/testl11|test.zip|26922546}

Containment Recommendations

- Add URI pattern /testl11 on 85.209.129.105:2020 to IDS/WAF detection rules.
- If PCAP retention allows, carve and sandbox-analyze test.zip.

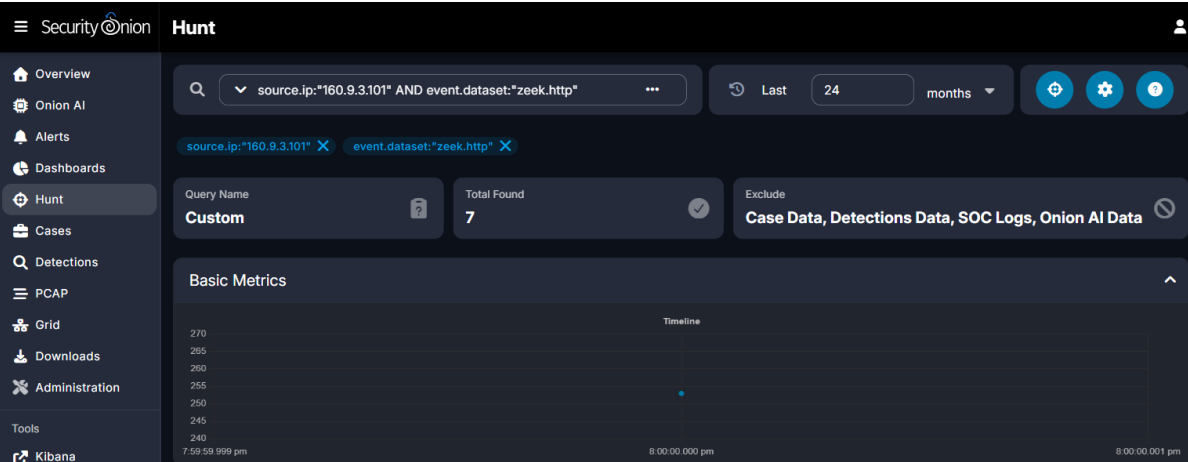
Conclusion

The ~26 MB test.zip archive represents the largest and likely most consequential payload delivered in the Phase 1 chain.

Evidence Screenshots

Figure 9a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	http.me
>	2025-10-01 05:00:47.201 -04:00	zeek.http	160.9.3.101	63641	85.209.129.105	2020	GET
>	2025-10-01 05:00:53.575 -04:00	zeek.http	160.9.3.101	63645	85.209.129.105	2020	GET
>	2025-10-01 05:00:57.970 -04:00	zeek.http	160.9.3.101	63649	85.209.129.105	2020	POST
>	2025-10-01 05:00:59.526 -04:00	zeek.http	160.9.3.101	63651	64.95.13.172	80	GET
>	2025-10-01 05:01:15.089 -04:00	zeek.http	160.9.3.101	63654	104.16.231.132	80	POST
>	2025-10-01 05:01:18.920 -04:00	zeek.http	160.9.3.101	63656	85.209.129.105	2020	GET
>	2025-10-01 05:04:37.969 -04:00	zeek.http	160.9.3.101	64928	142.250.114.102	80	GET

Items per page: 10 1-7 of 7

The backend data fetch took 0.02 seconds. The total round trip took 0.025 seconds.

Figure 9b - Evidence Step
The specific record expanded, showing the details that produced the answer above.

  file.resp_filenames	["test.zip"]
  file.resp_mime_types	["application/zip"]
  hash.sha4h	ge11nn030000_b0d6a43aa599_000000000000_000000000000
  http.method	GET
  http.request.body.length	0
  http.response.body.length	26922546
  http.status_code	200
  http.status_message	OK
  http.trans_depth	1
  http.uri	/test11

Challenge 10 of 10: Later TLS C2 Domain

Investigation Question: Which later TLS server name resolved to 91.212.166.160?

In Plain Words

After everything else happened, the victim's computer kept quietly calling out to a website named georgej.ru, again and again - nine times in under a minute. This kind of repeated, automatic calling out is how attackers secretly stay in control of a computer they have hacked.

Technical Method

Query used: source.ip:"160.9.3.101" AND destination.ip:"91.212.166.160" AND event.dataset:"zeek.ssl"

Queried all zeek.ssl sessions from the affected workstation to 91.212.166.160. Found 9 separate TLSv1.3 sessions between 09:04:35.412 and 09:05:06.643 UTC, all carrying ssl.server_name: georgej.ru.

Relevant Infrastructure

Type	Domain / IP	Port	Purpose / Observation
Command-and-Control Server	georgej.ru (91.212.166.160)	443	Repeatedly contacted (9 times) after script execution - the ongoing remote-control channel

Command-and-Control Assessment

georgej.ru (91.212.166.160) was contacted 9 times over TLSv1.3 within a ~31 second window, a pattern consistent with periodic C2 beaconing rather than normal browsing, occurring after the script-delivery and notification chain.

Supporting Evidence (Security Onion / Zeek)

- log.id.uid: Cayp7x1osJH5m9henj (first of 9 sessions)
- destination.ip: 91.212.166.160, destination.port: 443
- ssl.server_name: georgej.ru, ssl.version: TLSv1.3
- @timestamp: 2025-10-01T09:04:35.412Z (first occurrence)

Answer

Domain: georgej.ru (resolves to 91.212.166.160)

Submitted flag: CTk{georgej.ru}

Containment Recommendations

- Block georgej.ru and 91.212.166.160 at DNS/web proxy and perimeter firewall immediately.
- Prioritize this host for full endpoint forensic imaging given confirmed C2 activity.

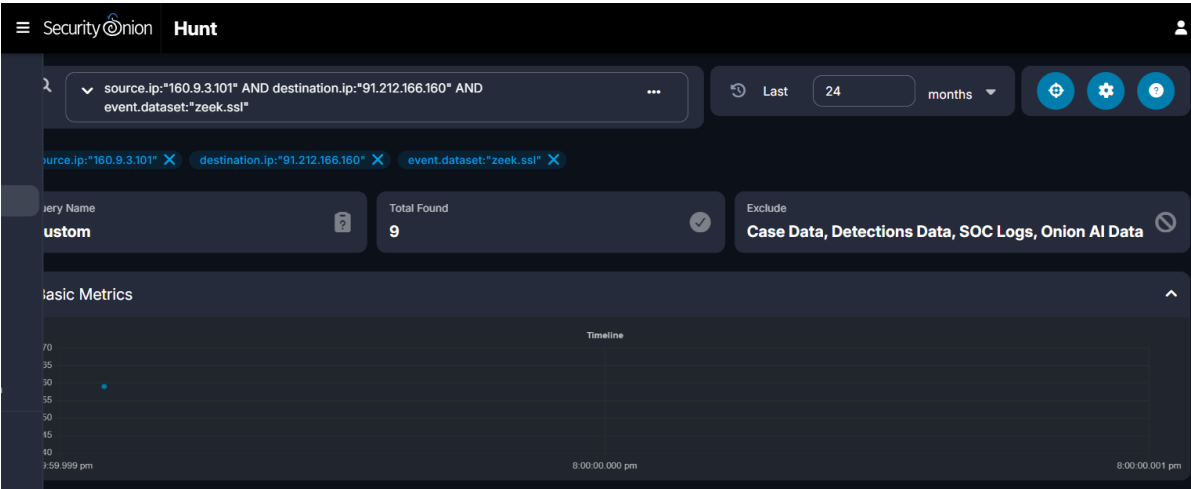
Conclusion

The repeated TLS beaconing to georgej.ru (91.212.166.160) confirms an active command-and-control channel was established on the affected workstation - the most operationally significant finding of Phase 1.

Evidence Screenshots

Figure 10a - Query Step

The Security Onion query used to begin this part of the investigation, and its result list.



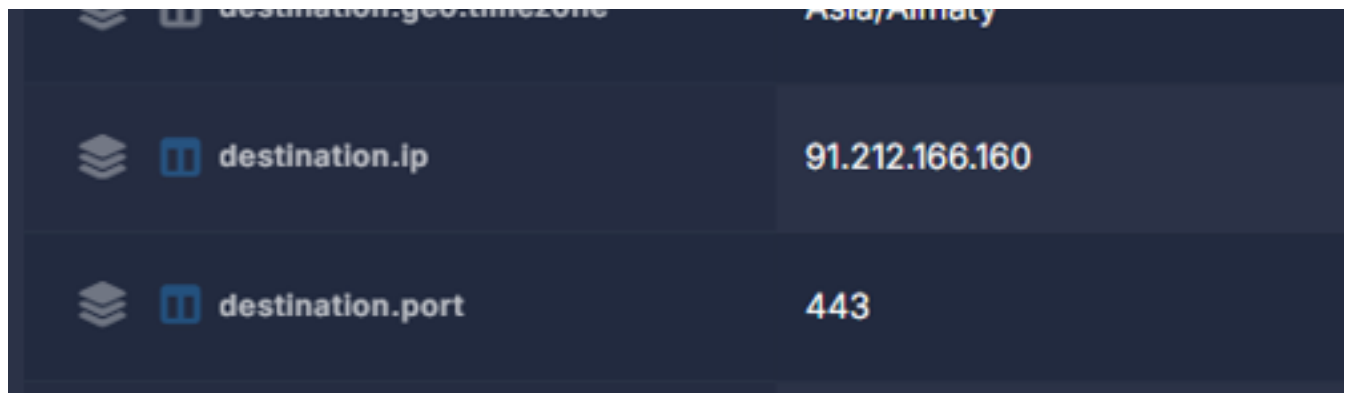
	Timestamp	event.dataset	source.ip	source.port	destination.ip	destination.port	ssl_server_name	ssl.valid
> ▲	2025-10-01 05:04:35.412 -04:00	zeek.ssl	160.9.3.101	55953	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:43.808 -04:00	zeek.ssl	160.9.3.101	55580	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:48.993 -04:00	zeek.ssl	160.9.3.101	55581	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:50.728 -04:00	zeek.ssl	160.9.3.101	55584	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:54.462 -04:00	zeek.ssl	160.9.3.101	55587	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:55.794 -04:00	zeek.ssl	160.9.3.101	55588	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:58.064 -04:00	zeek.ssl	160.9.3.101	55589	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:04:59.023 -04:00	zeek.ssl	160.9.3.101	55590	91.212.166.160	443	georgej.ru	
> ▲	2025-10-01 05:05:06.643 -04:00	zeek.ssl	160.9.3.101	55593	91.212.166.160	443	georgej.ru	

Items per page: 10 1-9 of 9

The backend data fetch took 0.019 seconds. The total round trip took 0.023 seconds.

Figure 10b - Evidence Step

The specific record expanded, showing the details that produced the answer above.



The image shows a dark-themed interface with a table of network data. The table has two visible rows. The first row shows 'destination.ip' with the value '91.212.166.160'. The second row shows 'destination.port' with the value '443'. Above the first row, a header row shows 'destination.geo.timezone' with the value 'Asia/Kolkata'. Each row has a small icon to its left, consisting of three stacked squares.

destination.geo.timezone	Asia/Kolkata
destination.ip	91.212.166.160
destination.port	443